

IT GOVERNANCE

Florence Love Nkosi, **CISA|CEH**

Governance

- Governance is “the combination of processes and structures implemented by the board to inform, direct, manage, and monitor the activities of the organization toward the achievement of its objectives.”

IT GOVERNANCE

- IT governance are rules and regulations under which an IT department functions. It also includes mechanisms, put in place to ensure compliance with those rules and regulations.
- IT governance is defined by the IPPF as: “IT governance consists of the leadership, organizational structures, and processes that ensure that the enterprise’s [IT] supports the organization’s strategies and objectives.”
- “The leadership and organizational structures and processes that e the organization's IT sustains and extends the organization's strateg objectives.“



IT GOVERNANCE

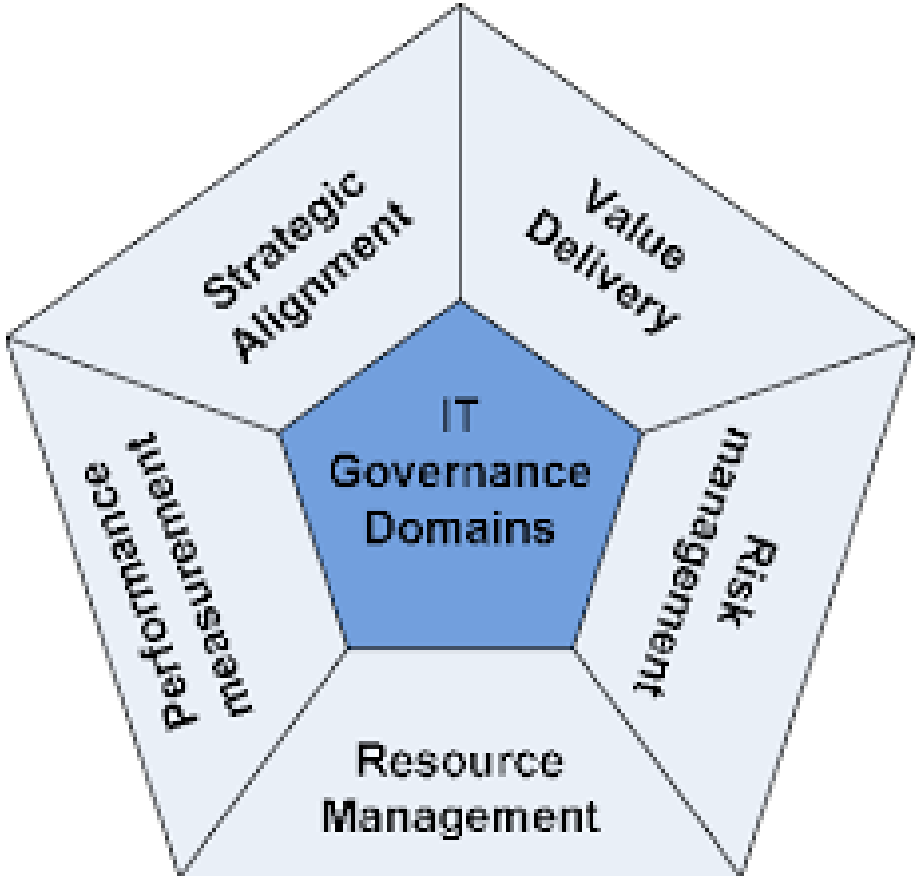
- IT governance helps to increase an organization's ability to achieve its overall goals and objectives.
- IT has become a major enabler to almost all business transformation initiatives.
- Generally then, IT governance is intended to facilitate the sustaining of organizational operations directed toward implementation of its general business strategies in the present and in the future.



IT Governance focus areas

IT governance should focus on five key areas:

- Strategic alignment with business;
- Value delivery;
- Risk management; and
- Resource management.
- Performance Management



Source: ITGI

IT Governance focus areas(2)

The five main focus areas and a short definition of each:

- **Strategic Alignment** — IT's goals are aligned with and supports the business goals and objectives
- **Value Delivery** — ensuring that IT delivers the promised benefits and concentrates on optimizing costs and proving the value of IT
- **Risk Management** — your job is to keep management aware of the risks the organization is facing with respect to IT, keeping in mind all the legal and regulatory requirements which surround IT
- **Resource Management** — in addition to optimizing costs, you will need to understand resource management, e.g. Are the high valued IT assets being used effectively and efficiently?
- **Performance Management** — Tracking the achievement of the objectives of the enterprise to achieve goals measurable beyond conventional accounting; and compliance with specific external requirements.
- .

BENEFITS OF IT GOVERNANCE

- Standardized process and procedures to better manage the IT environment
- Maximize return on investment
- More effective IT because of a closer alignment with the business
- Alignment with corporate objectives
- Consistency with IT strategy and policy
- Accountability and transparency in decision making that impacts on IT

Who Is Responsible for IT Governance?

- The board of directors
- IT executives
- Business executives,
- Internal auditors

Audit role in IT governance

- Audit plays a significant role in the successful implementation of IT governance within an organization
- Reporting on IT governance involves auditing at the highest level in the organization and may cross division, functional or departmental boundaries

Auditors Role in IT Governance

- To provide leading practice recommendations to senior management to help improve the quality and effectiveness of the IT governance initiatives implemented.
- Helps ensure compliance with IT governance initiatives implemented within an organization
- Continuous monitoring, analysis and evaluation of metrics associated with IT governance initiatives require an independent and balanced view to ensure a qualitative assessment that subsequently facilitates the qualitative improvement of IT processes and associated GEIT initiatives
- To check on alignment of the IT function with the organization's mission, vision, values, objectives and strategies
- To ensure compliance with legal, environmental, information quality, fiduciary, security and privacy requirements

IT Governance Frameworks

- For IT to be successful in delivering against business requirements, management should put an
internal control system or framework in place.
- These frameworks supports IT governance / implementation of IT Governance.

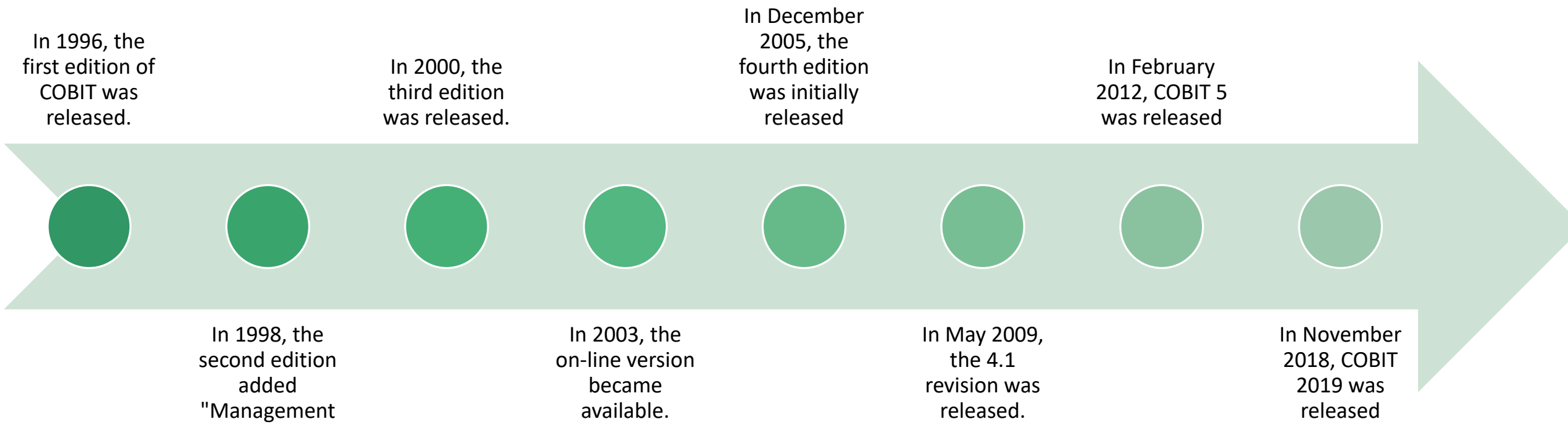
IT governance frameworks

1. **COBIT**: COBIT stands for Control Objectives for Information and Related Technologies. This framework is created by the Information Systems Audit and Control Association (ISACA) and is designed specifically for enterprise IT. COBIT is considered the industry standard best practice IT governance framework.
2. **ITIL**: ITIL is an acronym for Information Technology Infrastructure Library. This framework considers how IT service strategy, design, transition, operations, and service improvement can support core business practices.
3. **COSO**: The Committee of Sponsoring Organizations of the Treadway Commission (COSO) focuses on internal controls, rather than on IT-specific functions, integrating other frameworks like risk management and fraud prevention.
4. **ISO2700;** is a set of best practices that provides guidance to organizations implementing and maintaining information security programs.

COBIT

- **COBIT** at origination, was an abbreviation for Control Objectives for Information and related Technology.
- **COBIT (Control Objectives for Information and Related Technologies)** provide a business framework for the governance and management of IT.
- **COBIT** supplies globally accepted principles, practices, and analytical tools, and a growth road map that influences proven practices.
- **COBIT** focuses specifically on security, risk management and information governance.

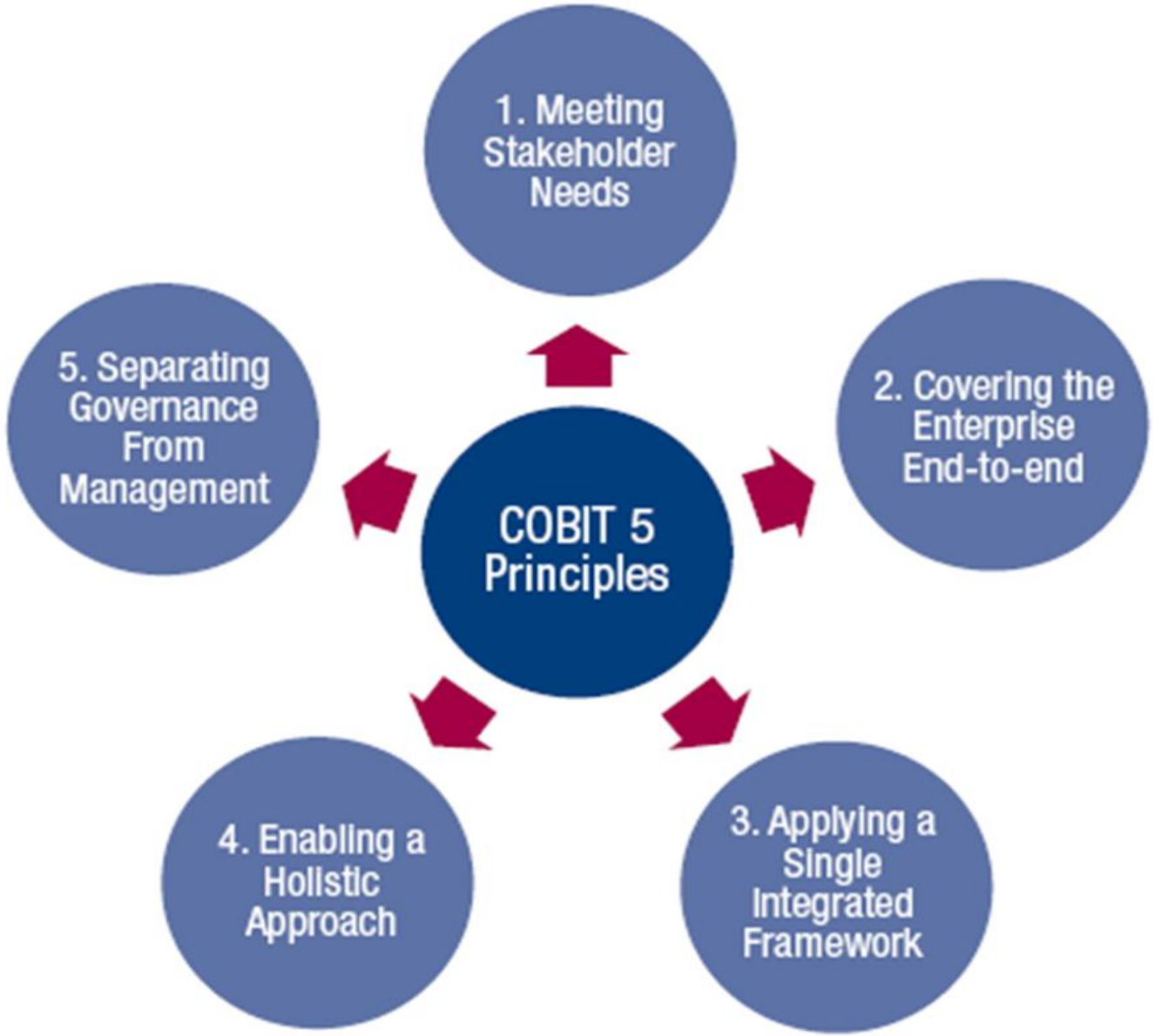
HISTORY OF COBIT



Benefits of COBIT

- Improve and maintain high-quality information to support business decisions.
- Use IT effectively to achieve business goals.
- Use technology to promote operational excellence.
- Ensure IT risk is managed effectively.
- Ensure organizations realize the value of their investments in IT.
- Achieve compliance with laws, regulations and contractual agreements.

COBIT PRINCIPLES



COBIT 5 Principle 1: Meeting the Needs of the Stakeholder

- Businesses or enterprises exists to create value for stakeholders.
- COBIT 5 enables the transformation of the needs of the stakeholders into a more practical and achievable strategy.
- This principle focuses on the governance, negotiation, and decision making about the various conflicting needs of the stakeholders.
- This assures that whenever the benefit, resources, and risk-assessment decisions are made for delivering the value, the needs of the stakeholders is taken into consideration.



COBIT 5 Principle 1: Meeting the Needs of the Stakeholder

- COBIT 5 enables the transformation of the needs of the stakeholders into a more practical and achievable strategy.
- COBIT 5 strives to maintain a balance between the use of available resources and the realisation of the benefits of keeping in consideration the associated risks.
- This principle focuses on the governance, negotiation, and decision making about the various conflicting needs of the stakeholders.
- This assures that whenever the benefit, resources, and risk-assessment decisions are made for delivering the value, the needs of the stakeholders is taken into consideration.
- It uses a mechanism called the COBIT 5 Goals Cascade, which translates the needs of the stakeholder into more specific and manageable approach which are then mapped to specific processes and practices.

COBIT 5 Principle 2: Covering the entirety of the Project

- In this approach, COBIT performs the integration of IT governance and enterprise governance and includes all the processes used to manage information and technology.
- The overall business processes and IT services are included in the COBIT 5. The four main elements of this end-to-end approach are as follows:
  - The objective of governance for creating value
  - The enablers, which can individually or collectively decide what will work
  - Deciding the scope
  - Assigning roles, responsibilities, and activities

Principle 3: Applying a Single Integrated Framework

- The COBIT 5 enables the organizations to have a single Integrated Framework, providing an enterprise coverage and consistency, and it also can be customized as per the needs of the organisation. COBIT 5 can retain the position of a single Integrated Framework due to the following reasons:

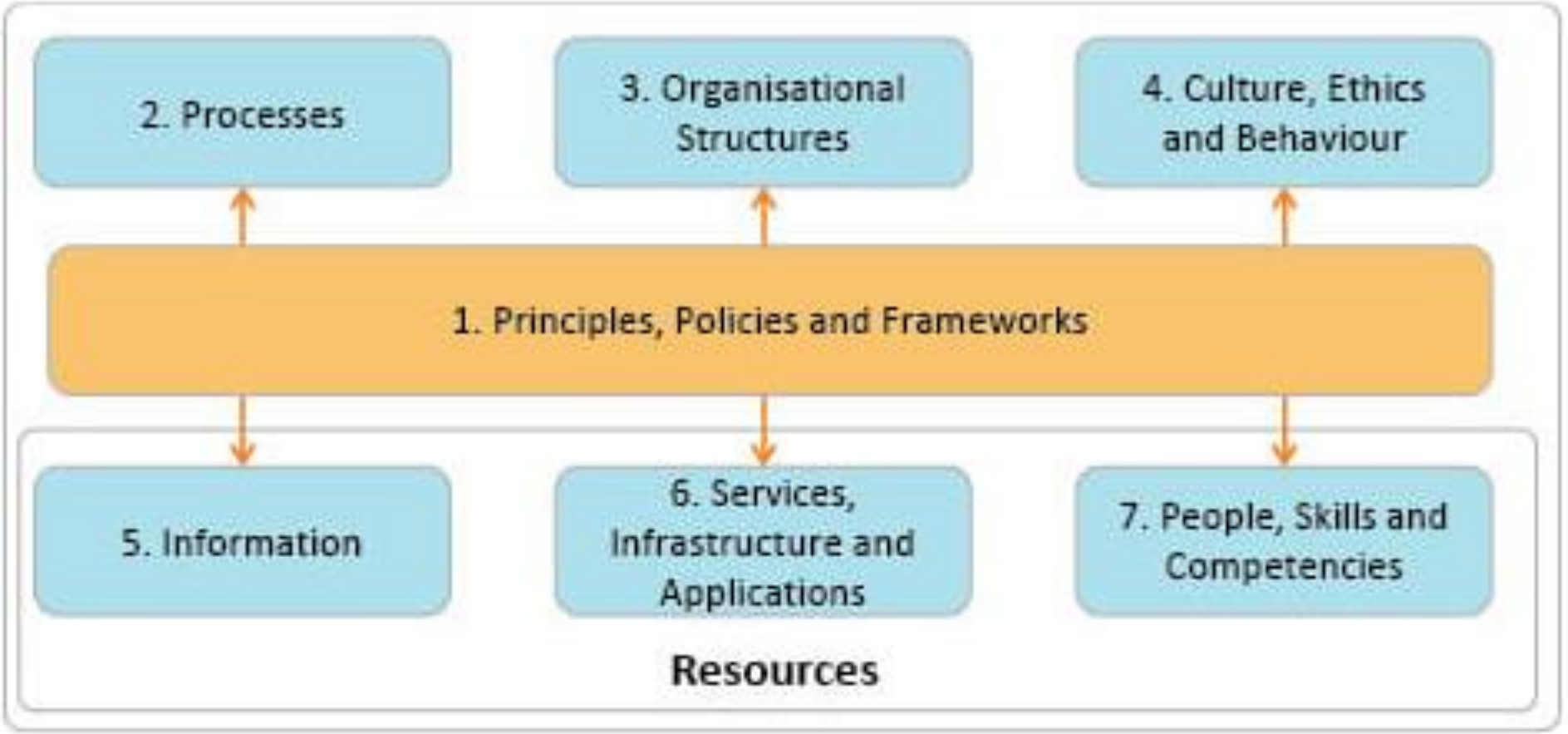
  • COBIT 5 acts as a single integrated source of direction, even for the non-technical terms of language.

  • COBIT 5 aligns itself with relevant standards and frameworks such as ITIL and ISO standards.

  • Taking into account the latest standards and frameworks, COBIT 5 composes itself as a ‘Superstructure’ by aligning all the management and governance activities.

COBIT Principle 4: Enabling Holistic Approach

- COBIT 5 facilitates effective management and governance of IT across the organisation by the means of ‘enablers.’ Enablers are the factors driving the outcome of activities that are governance and management related.
- Enablers can be applied across the entire organization, including all the internal and external resources relevant to the governance and management of IT.
- Enablers are defined as factors that, individually and collectively, influence the success of an initiative and are driven by the goals cascade.


2. Processes
3. Organisational Structures
4. Culture, Ethics and Behaviour
1. Principles, Policies and Frameworks
5. Information
6. Services, Infrastructure and Applications
7. People, Skills and Competencies
Resources

COBIT Principle 4: Enabling Holistic Approach(2)

1. **Processes**—Describe an organised set of practices and activities to achieve certain objectives and produce a set of outputs in support of achieving overall IT related goals.

2. **Organisational structures**—Are the key decision-making entities in an organisation.

3. Culture, ethics and behaviour—Of individuals and of the organisation; very often underestimated as a success factor in governance and management activities.

4. Principles, policies and frameworks—Are the vehicle to translate the desired behaviour into practical guidance for day-to-day management.

5. Information—Is pervasive throughout any organisation, i.e., deals with all information produced and used by the enterprise. Information is required for keeping the organisation running and well governed, but at the operational level, information is very often the key product of the enterprise itself.

6. Services, infrastructure and applications—Include the infrastructure, technology and applications that provide the enterprise with information technology processing and services.

7. People, skills and competencies—Are linked to people and are required for successful completion of all activities and for making correct decisions and taking corrective actions.

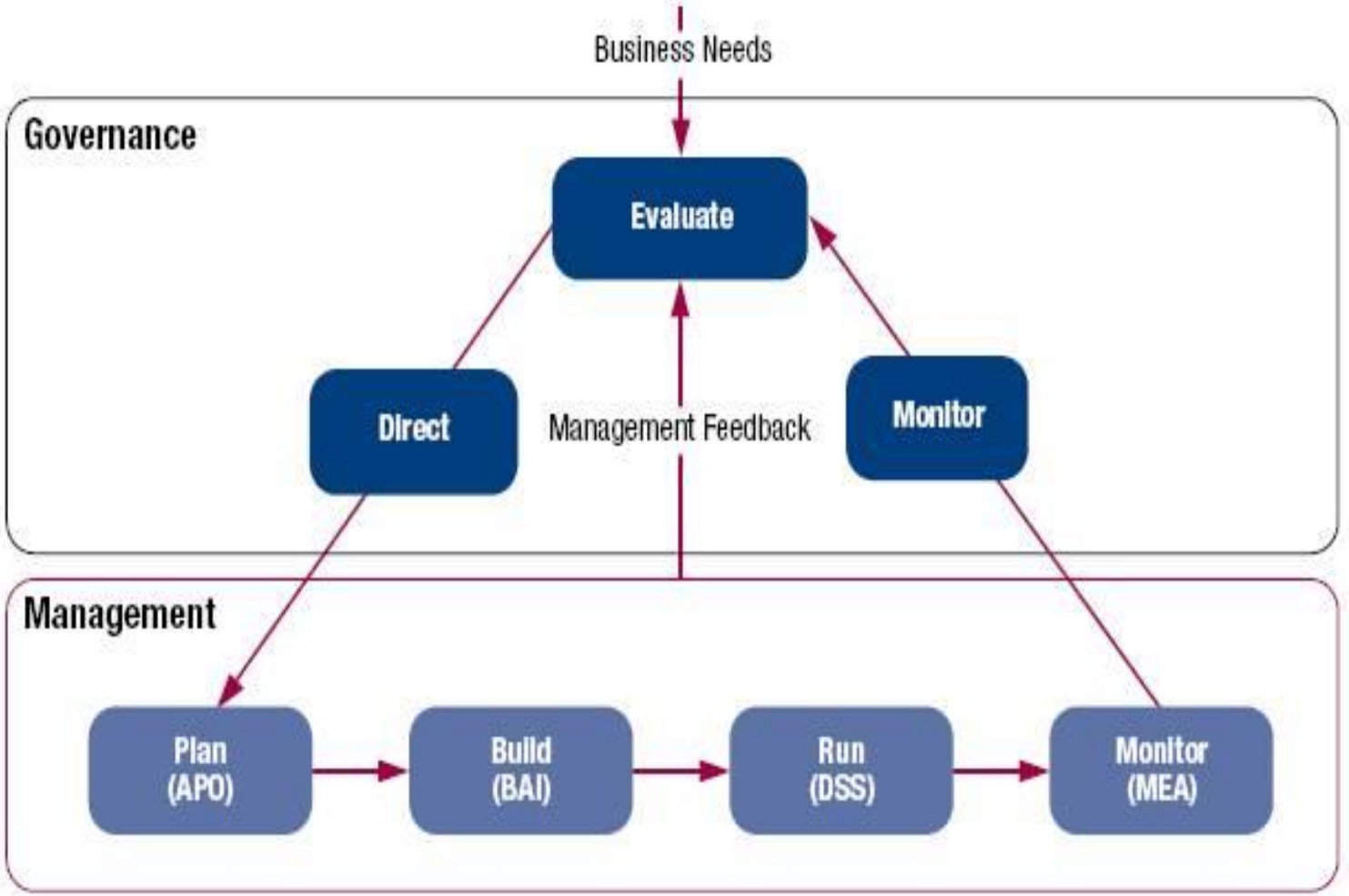
COBIT Principle 5: Separating Governance from Management

- The COBIT 5 framework makes a clear distinction between governance and management.
- These two disciplines:
  - – Encompass different types of activities
  - – Require different organisational structures
  - – Serve different purposes
- Governance—In most enterprises, governance is the responsibility of the board of directors under the leadership of the chairperson.
- Management—In most enterprises, management is the responsibility of the executive management under the leadership of the CEO.

COBIT Principle 5: Separating Governance from Management (cont.)

- **Governance** ensures that enterprise objectives are achieved by **evaluating** stakeholder needs, conditions and options; setting **direction** through prioritisation and decision making; and **monitoring** performance, compliance and progress against agreed direction and objectives **(EDM)**
- **Management plans, builds, runs** and **monitors** activities in alignment with the direction set by the governance body to achieve the enterprise objectives (PBRM)

COBIT advocates that organizations implement governance and management processes such that the key areas are covered, as shown in the Picture.



COBIT Domains

COBIT groups IT control processes into four broad domains:

- Planning & Organization (PO)
- Acquisition & Implementation(AI)
- Delivery & Support (DS)
- Monitor and Evaluate (ME)

COBIT DOMAINS

- Document Provided for Reading of the notes. A summary of the Domains is covered in the following Slides.

Planning and organizations

- This domain covers strategy and tactics, and concerns the identification of the way IT can best contribute to the achievement of the business objectives.
- Furthermore, the realization of the strategic vision needs to be planned, communicated and managed for different perspectives.
- Finally, a proper organization as well as technological infrastructure must be put in place.

Planning And Organization

- PO1 Define a strategic IT plan.
- PO2 Define the information architecture.
- PO3 Determine technological direction.
- PO4 Define the IT processes, organization and relationships.
- PO5 Manage the IT investment.
- PO6 Communicate management aims and direction.
- PO7 Manage IT human resources.
- PO8 Manage quality.
- PO9 Assess and manage IT risks.
- PO10 Manage projects.

Acquisition and Implementation

- To realize the IT strategy, IT solutions need to be identified, developed or acquired, as well as implemented and integrated into the business process.
- In addition, changes in and maintenance of existing systems are covered by this domain to make sure that the life cycle is continued for these systems.

Acquisition and Implementation

- AI1 Identify automated solutions.
- AI2 Acquire and maintain application software.
- AI3 Acquire and maintain technology infrastructure.
- AI4 Enable operation and use.
- AI5 Procure IT resources.
- AI6 Manage changes.
- AI7 Install and accredit solutions andchanges.

Delivery and Support

- This domain is concerned with the actual delivery of required services, which range from traditional operations over security and continuity aspects to training.
- In order to deliver services, the necessary support processes must be set up.
- This domain includes the actual processing of data by application systems, often classified under application controls.

Delivery and support

- DS1 Define and manage service levels.
- DS2 Manage third-party services.
- DS3 Manage performance and capacity.
- DS4 Ensure continuous service.
- DS5 Ensure systems security.
- DS6 Identify and allocate costs.
- DS7 Educate and train users.
- DS8 Manage service desk and incidents.
- DS9 Manage the configuration.
- DS10 Manage problems.
- DS11 Manage data.
- DS12 Manage the physical environment.
- DS13 Manage operations

Monitoring

- All IT processes need to be regularly assessed over time for their quality and compliance with control requirements.
- This domain thus addresses management’s oversight of the organization's control process and independent assurance provided by internal and external audit or obtained from alternative sources.

Monitor and Evaluate

- ME1 Monitor and evaluate IT performance.
- ME2 Monitor and evaluate internal control.
- ME3 Ensure compliance with external requirements.
- ME4 Provide IT governance.

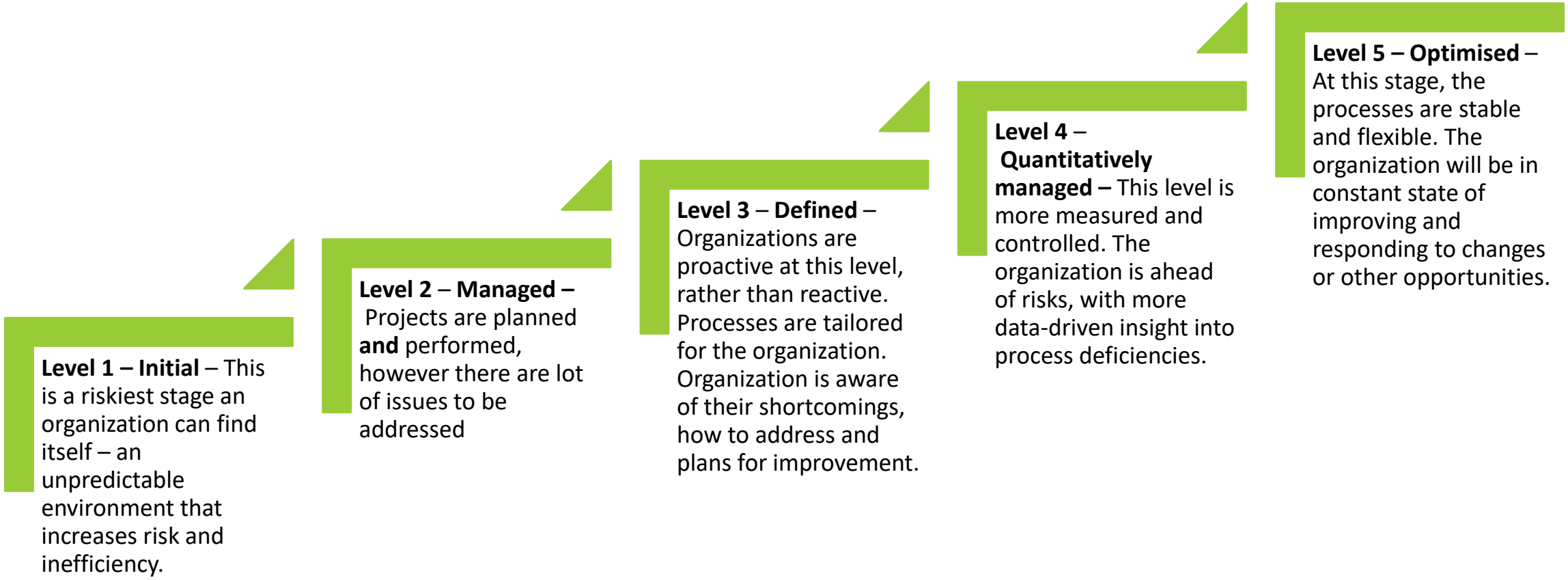
Maturity and Process Improvement Models

- Implementation of IT governance requires ongoing performance measurement of an organization's resources that contribute to the execution of processes that deliver IT services to the business
- Some of the process improvement models are:
  - The COBIT Process Assessment Model **(PAM),** using COBIT 5,
  - Capability Maturity Model

Capability Maturity Model Integration (CMMI)

- **Capability Maturity Model Integration (CMMI) –** is a process improvement approach that provides enterprises with the essential elements of effective processes.
- It is based on ISO/IEC 15504 Information Technology—Process Assessment standard.
- CMMI have five maturity levels

Capability Maturity Model Integration (CMMI)



IT GOVERNING COMMITIES

There are two main governing committees:

- IT Steering Committee
- IT strategy Committee

IT GOVERNING COMMITIES

IT Steering Committee

- Advises the board and management on IT strategy
- Is delegated by the board to provide input to the strategy and prepare its approval
- Focuses on current and future strategic IT issues
- Provides insight and advice to the board on topics such as:
- The alignment of IT with the business direction
- The availability of suitable IT resources, skills and infrastructure to meet the strategic objectives
- The achievement of strategic IT objectives

Composition

- Board members
- Specialist non-board members

IT GOVERNING COMMITIES

IT strategy Committee

- Assists the executive in the delivery of the IT strategy
- Oversees day-to-day management of IT service delivery and IT projects
- Focuses on implementation
- Decides the overall level of IT spending and how costs will be allocated
- Approves project plans and budgets, setting priorities and milestones
- Communicates strategic goals to project teams
- Monitors resource and priority conflict between enterprise divisions and the IT function as well as between projects
- Report to the board of directors on IS activities.
- Make decisions regarding centralization versus decentralization and assignment of responsibility.

Composition

- Sponsoring executive
- Business executive (key users)
- Chief information officer (CIO)
- Key advisors as required (IT, audit, legal, finance)

Auditing IT Governance Structure and Implementation

- Review relevant documentation, including the current organizational chart, mission statement, and job descriptions for key functions, to determine if individuals or groups are performing incompatible functions.
- Review systems documentation and maintenance records for a sample of applications.
- Verify that maintenance programmers assigned to specific projects are not also the original design programmers.
- Verify that computer operators do not have access to the operational details of a system's internal logic. Systems documentation, such as systems flowcharts, logic flowcharts, and program code listings, should not be part of the operation's documentation set.
- Through observation, determine that segregation policy is being followed in practice. Review operations room access logs to determine whether programmers enter the facility for reasons other than system failures.

Auditing IT Governance Structure and Implementation

- Verify that corporate policies and standards for systems design, documentation, and hardware and software acquisition are published and provided to distributed IT units

Risk Management

- The process of identifying vulnerabilities and threats to the information resources used by an organization in achieving business objectives and what countermeasures to take in reducing risk to an acceptable level.
- encompasses identifying, analyzing, evaluating, treating, monitoring and communicating the impact of risk on IT processes

Risk Management Process

1. Asset Identification
2. Evaluation of threats and vulnerabilities
3. Evaluation of impact
4. Calculation of risk
5. Evaluation and response to risk

RISK Management

The Board may choose to treat the risk in any of the following ways:

- **Avoid**—Eliminate the risk by eliminating the cause
- **Mitigate**—Lessen the probability or impact of the risk by defining, implementing and monitoring appropriate controls
- **Share/Transfer** (deflect, or allocate)—Share risk with partners or transfer via insurance coverage, contractual agreement or other means
- **Accept**—Formally acknowledge the existence of the risk and monitor it.

Policies and Procedures

- Policies and procedures reflect management guidance and direction in developing controls over information systems, related resources and IS department process.
- Policies are high level documents that represents the corporate philosophy of an organization.
- Policies must be clear and concise
- Management should review all policies periodically
- Policies need to be updated to reflect new technology, changes in environment and significant changes in business processes.
- Policies formulated must support achievement of business objectives and implementation IS controls.
- IS auditors should understand that policies are part of the audit process and should test the policies for compliance.
- IS auditors should use the policies as a benchmark for evaluating compliance.

Information security policy

- IS policy communicates a coherent security standard to users, Management and technical staff.
- A security policy is the first step towards building the security infrastructures for technology driven organisations.
- The security policy must be approved by senior Management and should be documented and communicated as appropriate to all employees, service providers and business partners.
- The IS Policy should be used by IS Auditor as a reference framework for perfoming various IS Audit assignments.
- The information security policy should state managements commitment and set out the organisations approach to managing information security.

Procedures

- Steps defined and documented for implementing policies
- They MUST be derived from the parent policy and must implement the spirit of the policy statement .
- Procedures must be written in a cear and consice manner so they may be easily properly understood by those governed by them.
- Procedures are formulated by process owners as an effective translation of policies..

Thank You !!